Un secret par site

Activité — réutilisation des mots de passe et gestionnaire

BTS SIO 1re année

Cybersécurité

Objectifs

- Tracer les conséquences d'une fuite quand un mot de passe est réutilisé.
- Estimer l'entropie d'un mot de passe et repérer ceux qu'un dictionnaire trouve.
- Choisir un gestionnaire de mots de passe et expliquer ce qu'il protège.

Prérequis

- Identification, authentification, autorisation ; formule de l'entropie (cours du matin).
- Les besoins DICP.

Sommaire

Étape	Contenu
Étape 1	Le cas de Léa (15 min)
Étape 2	Mesurer six mots de passe (15 min)
Étape 3	Choisir un gestionnaire (15 min)
Étape 4	Trace individuelle (10 min)

Consignes

En binôme, sur papier ou sur poste, 55 minutes. Les réponses sont rédigées par chacun. IA interdite : vous devez pouvoir justifier chaque réponse vous-même.

> **Règle.** Tous les mots de passe de cette fiche sont fictifs. N'écrivez, ne saisissez et ne testez jamais un de vos vrais mots de passe, ni ici, ni sur un site de « test de mot de passe ».

Étape 1 — Le cas de Léa

15 minutes. Léa est technicienne chez Soft-Tech. Voici ses comptes.

Compte	Identifiant	Mot de passe
Forum RétroGamers	`lea.martin.perso@exemple.fr`	`Mistral2019!`
Messagerie personnelle	`lea.martin.perso@exemple.fr`	`Mistral2019!`
Boutique en ligne (carte enregistrée)	`lea.martin.perso@exemple.fr`	`Mistral2019!`
Messagerie Soft-Tech	`lea.martin@soft-tech.fr`	`Mistral2019!`
Facturation Soft-Tech	`lea.martin@soft-tech.fr`	`Mistral2019!`

Lundi, la base du forum RétroGamers est volée puis publiée : adresses et mots de passe.

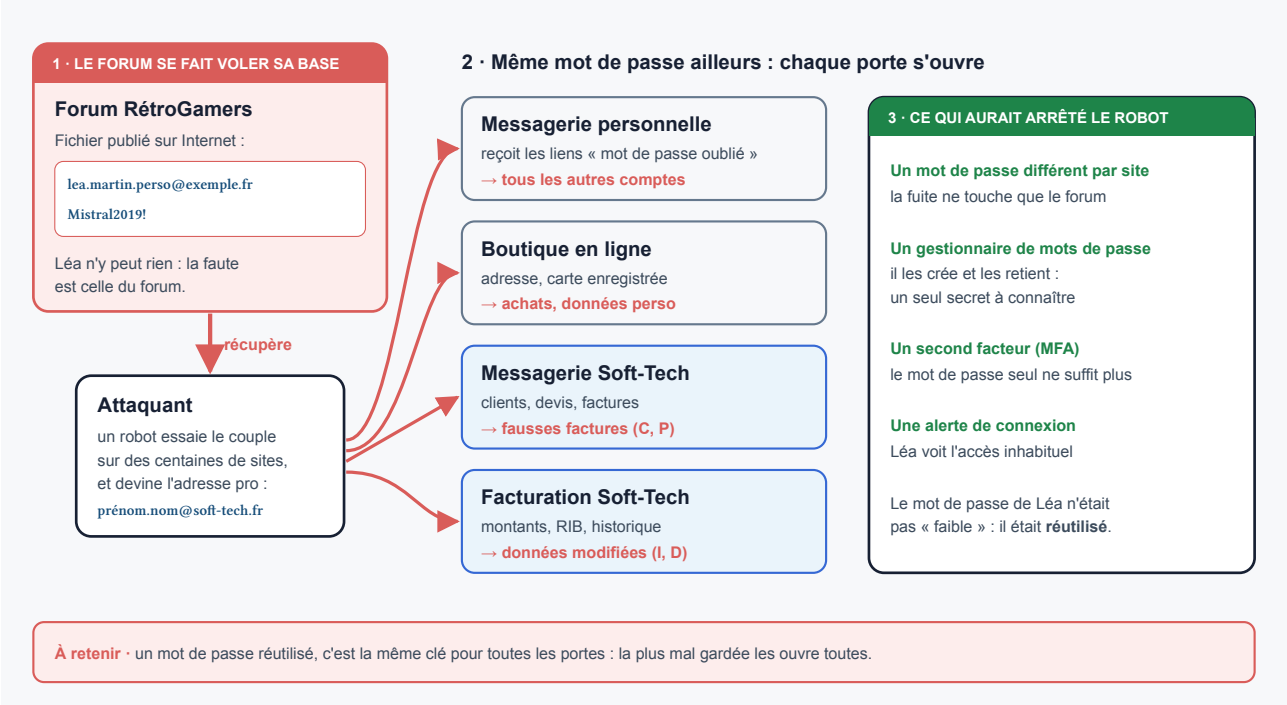


Fig. 1 - Une fuite, toutes les portes : le robot de l'attaquant essaie le couple volé sur les autres comptes de Léa.

1. Quels comptes l'attaquant peut-il ouvrir ? Pourquoi les comptes Soft-Tech aussi, alors que l'identifiant est différent ?
2. Pour chaque compte, donnez une conséquence possible et le besoin DICP touché.
3. Pourquoi la messagerie personnelle est-elle le compte le plus grave à perdre ?
4. Léa a-t-elle commis une faute en s'inscrivant sur le forum ? Où est sa vraie erreur ?

À produire : un tableau compte ⟶ conséquence ⟶ besoin DICP, et la réponse à la question 4.

Étape 2 — Mesurer six mots de passe

15 minutes. Rappel : entropie = L × $\log_2(N)$.

Caractères	Chiffres	Minuscules	Lettres	Lettres et chiffres	Tout le clavier
N	10	26	52	62	95
$\log_2(N)$	3,3	4,7	5,7	6,0	6,6

Calculatrice d'entropie : elle est disponible sur la page web de cette activité. Sur papier, utilisez le tableau ci-dessus.

Mot de passe	Entropie calculée	Dans un dictionnaire ?	Verdict
`123456`			
`azerty`			
`Mistral2019!`			
`vQ7#pL2x`			
`tulipe-orbite-glacier-banjo-sept`			
`Kq8!zR3m#Lw5vT`			

1. Complétez le tableau. Pour la phrase de passe, comptez **par mot** : les mots sont tirés dans une liste de 7 776 mots, et $\log_2(7\,776) \approx 12{,}9$.
2. Lequel est le plus fort ? Lequel retiendriez-vous ?
3. Si on compte la phrase de passe lettre par lettre, on trouve environ 150 bits. Pourquoi ce calcul est-il faux ?

À produire : le tableau complété et une phrase de conclusion.

Étape 3 — Choisir un gestionnaire

15 minutes. Un gestionnaire crée un mot de passe différent et aléatoire pour chaque site, le retient, et le remplit à votre place. Vous n'en retenez plus qu'un : le **mot de passe principal**.

Gestionnaire	Prix (usage personnel)	Appareils	Particularité
Bitwarden	Gratuit, option payante	Tous (Windows, macOS, Linux, Android, iOS)	Code source ouvert, offre pour les entreprises
1Password	Abonnement	Tous	Coffres partagés en famille ou en équipe
Mots de passe d'Apple	Gratuit	Appareils Apple, Windows avec iCloud	Intégré au système, pas d'Android
KeePassXC	Gratuit	Windows, macOS, Linux	Fichier local, aucune synchronisation fournie

1. Léa a un téléphone Android et un ordinateur Windows. Que lui conseillez-vous ? Pourquoi pas Mots de passe d'Apple ?
2. Soft-Tech veut partager les accès aux comptes fournisseurs entre trois techniciens. Lequel choisir, et pourquoi pas une feuille de calcul partagée ?
3. Tout repose sur le mot de passe principal. Comment doit-il être construit, et que faut-il ajouter pour qu'il ne suffise pas à lui seul ?
4. Le gestionnaire refuse de remplir le mot de passe sur `soft-tech-factures.com` alors que le vrai site est `soft-tech.fr`. En quoi est-ce une protection contre l'hameçonnage ?

À produire : une recommandation pour Léa et une pour Soft-Tech, justifiées en deux lignes.

Étape 4 — Trace individuelle

10 minutes, seul. Trois phrases, sans regarder la fiche :

1. La différence entre identification et authentification.
2. Pourquoi un mot de passe fort, réutilisé, reste un risque.
3. Ce qu'un gestionnaire de mots de passe change pour l'utilisateur.

Vérification avant de terminer

- [ ] Je sais expliquer comment une fuite sur un site ouvre d'autres comptes.
- [ ] Je calcule une entropie et je sais quand le calcul se trompe.
- [ ] Je sais conseiller un gestionnaire adapté à des appareils donnés.
- [ ] Mes trois phrases sont rédigées sans aide.

Corrigés

Activité — réutilisation des mots de passe et gestionnaire

BTS SIO 1re année

Cybersécurité

Étape 1

1. Tous. L'attaquant essaie le couple sur d'autres sites (*credential stuffing*). L'adresse professionnelle se devine (`prénom.nom@soft-tech.fr` , visible sur le site ou un réseau social) : seul le mot de passe protégeait, et il est connu.
2. Messagerie personnelle : lecture des messages (C), réinitialisation des autres comptes. Boutique : achats avec la carte, adresse (C, et données personnelles au sens du RGPD). Messagerie Soft-Tech : fausses factures envoyées aux clients au nom de Soft-Tech (C, P). Facturation : montants ou RIB modifiés (I), factures supprimées (D).
3. Elle reçoit les liens « mot de passe oublié » : qui la contrôle peut changer le mot de passe de presque tous les autres comptes, même ceux qui avaient un mot de passe unique.
4. Non : la fuite est la faute du forum. L'erreur de Léa est la **réutilisation**, qui transforme la fuite d'un site sans enjeu en accès à l'entreprise.

Étape 2

Mot de passe	Entropie calculée	Dictionnaire ?	Verdict
`123456`	6 × 3,3 ≈ 20 bits	Oui, le plus courant	Nul
`azerty`	6 × 4,7 ≈ 28 bits	Oui	Nul
`Mistral2019!`	12 × 6,6 ≈ 79 bits	Oui, par règles : mot + année + `!`	Faible
`vQ7#pL2x`	8 × 6,6 ≈ 53 bits	Non	Moyen : trop court
`tulipe-orbite-glacier-banjo-sept`	5 × 12,9 ≈ 65 bits	Non (mots tirés au hasard)	Bon et mémorisable
`Kq8!zR3m#Lw5vT`	14 × 6,6 ≈ 92 bits	Non	Fort, mais impossible à retenir : gestionnaire

Question 3 : l'attaquant ne devine pas lettre par lettre, il essaie des combinaisons de mots de la liste. Le nombre de possibilités est $7\,776^5$, pas 27^{32}.

Étape 3

1. Bitwarden (gratuit, Android et Windows). Mots de passe d'Apple ne fonctionne pas sur Android.
2. 1Password ou Bitwarden en offre d'équipe : coffre partagé, droits par personne, accès retiré au départ d'un technicien. Une feuille de calcul garde les mots de passe en clair, se copie, et ne dit pas qui a consulté quoi.
3. Une longue phrase de passe tirée au hasard, utilisée nulle part ailleurs, avec un second facteur (application d'authentification ou clé de sécurité).
4. Le gestionnaire compare le nom de domaine, pas l'apparence de la page : une copie parfaite sur un autre domaine ne reçoit rien. L'humain, lui, se fait tromper par l'apparence.